

COMPLIANCE AUDIT REPORT

Continuous Compliance Monitoring

Prepared for

March 28, 2026

[Company Name]

Version 1.0

Auditor: [Sharifa S.]

AWS Account: XXXXXXXXXXXX | Region: us-east-1

Assessment period: Q1 2026

CONFIDENTIAL

1. Executive Summary

This report presents the results of an automated compliance assessment conducted against [Company Name]'s AWS environment (account XXXXXXXXXXXX, region us-east-1) during the period Q1 2026. Evidence was collected automatically using boto3 collectors attached to CloudTrail, AWS Config, IAM, and Security Hub, with results committed to a git repository to provide a continuous, tamper-evident audit trail. The overall compliance posture is at risk, with an average pass rate of 46% across all four frameworks assessed. Of 36 framework controls evaluated, 9 are passing and 27 require remediation. A total of 77 individual findings were identified, of which 19 are rated HIGH or CRITICAL severity and require priority attention.

Assessment at a glance

Assessment date	March 28, 2026
AWS account	XXXXXXXXXXXX
Region	us-east-1
Frameworks assessed	PCI-DSS v4.0, SOC 2 Type II, ISO 27001:2022, ISO 42001:2023
Controls evaluated	36
Controls passing	9
Controls failing	27
Total findings	77
HIGH / CRITICAL findings	19
Overall posture	46% (at risk)

Framework posture

Framework	Pass rate	Signals	Controls	Posture
PCI-DSS v4.0	39%	7 / 18	19	At Risk
SOC 2 Type II	42%	8 / 19	5	At Risk
ISO 27001:2022	42%	8 / 19	8	At Risk
ISO 42001:2023	60%	6 / 10	4	Needs Improvement

2. Scope and Methodology

Assessment scope

This assessment covers the AWS environment identified above. Evidence was collected from four AWS services, each mapped to a dedicated collector. All evidence is stored as timestamped JSON artifacts committed to a git repository, providing an immutable audit trail that can be inspected at any point in time.

Evidence sources

- **CloudTrail (`aws_cloudtrail_logs`):** Trail configuration, log validation status, write event activity over 90-day lookback
- **AWS Config (`aws_config_rules`):** Rule compliance status, non-compliant resource details, high-value rule failure tracking
- **IAM (`aws_iam_posture`):** Password policy, root account posture, per-user MFA status, access key age analysis
- **Security Hub (`aws_securityhub_findings`):** Hub enablement, enabled standards, active findings by severity (CRITICAL/HIGH sample)

Frameworks assessed

- **PCI-DSS v4.0:** Payment Card Industry Data Security Standard — requirements for organisations that handle cardholder data
- **SOC 2 Type II:** AICPA Trust Services Criteria — Security, Availability, and Confidentiality principles
- **ISO 27001:2022:** International standard for information security management systems
- **ISO 42001:2023:** International standard for AI management systems — governance of AI systems and models

Evidence collection approach

Evidence is collected automatically on a weekly schedule via GitHub Actions, using short-lived OIDC credentials to assume a read-only AWS IAM role. No long-lived access keys are stored anywhere. Each collector saves its output in a standard envelope format — `evidence_id`, `collected_at`, `aws_account`, `aws_region`, `status`, `data` — and commits both a `latest.json` (for quick status checks) and a timestamped snapshot (for audit trail purposes) to the repository.

A single evidence artifact can satisfy controls across multiple frameworks simultaneously. For example, an IAM credential report satisfies MFA controls in PCI-DSS 8.4.2, SOC 2 CC6.1, ISO 27001 A.5.17, and ISO 42001 6.4.1 in a single collection run. This overlap is made explicit in the `controls.yaml` mapping file, which is the machine-readable risk register underlying this report.